

HackTheBox: Dashboard Review Assessment

Scenario:

I am working in Eagle (fictional company) as a SOC Tier 1 Analyst. Yesterday was my onboarding day with the company, and today I will be familiarized with the SOC. My day will begin by meeting up with a senior analyst, who will provide me with an insights into the environment, and afterwards, I will be expected to begin monitoring alerts and security events in our SOC dashboards.

Following are my notes after meeting the senior analyst, who provided insights into the environment:

- 1) The organization has moved all hosting to the cloud; the old DMZ network is closed,
- 2) so no more servers exist there.
- 3) The IT operation team consists of four people. They are the only ones with high privileges in the environment.
- 4) The IT operation team often tends to use the default administrator accounts even if they are told otherwise.
- 5) All endpoint devices are hardened according to CIS hardening baselines. Whitelisting exists to a limited extent.
- 6) IT security has created a privileged admin workstation and requires all admin activities be performed on this machine.
- 7) The Linux environment is primarily 'left over' servers from back in the day, which have very little, if any, activity on a regular day. The root user account is not used; due to audit findings, the account was blocked from connecting remotely, and users who require those rights will need to escalate via sudo command.
- 8) Naming conventions exists and are strictly followed; for example, service accounts contain '-svc' as part of their name. Service accounts are created with long, complex passwords, and they perform a very specific task.

Tasks:

We are provided with multiple visualizations within “**SOC-Alert**” dashboard:

- 1) Failed logon attempts [All users]
- 2) Failed logon attempts [Disabled user]
- 3) Failed logon attempts [Admin users only]
- 4) RDP logon for service account
- 5) User added or removed from a local group (March 5, 2023 to Now)

6) Admin Logon not from PAW (Feb 28, 2023 to Now)

7) SSH Logins

1. Analyzing Failed Logon Attempts [All users]

For Failed logon attempts, we can notice there is nothing suspicious or any obvious brute-force attack here.

However, **sql-svc1** has 2 failed network logons attempt which could possibly be due to:

- Misconfigured service
- Someone trying to use that service account to authenticate manually

We can consult with the **IT operations** to consult if there were any recent password changes before escalating. If there was nothing expected, then we can escalate to **Tier2/3 analyst**.

The screenshot shows a table of failed logon attempts. The table has four columns: Username, Event logged by, Logon type, and # of logins. The data is as follows:

Username	Event logged by	Logon type	# of logins
PAW	DC2	Network	4
Administrator	DC1	Interactive	3
administrator	PAW	Interactive	2
hdb	WS001	Interactive	2
sql-svc1	PAW	Network	2
Administrator	DC1	Unlock	1
administrator	PAW	Unlock	1
administrator	DC2	Interactive	1
anni	WS001	Interactive	1
uAdministrator	DC1	Network	1
uagileAdministrator	DC1	Network	1

2. Analyzing Failed Logon Attempts [Disabled User]

From the visualization it can be seen one failed logon attempt has been made by **username: Anni**.

- 1) **Policy Violation:** A logon attempt was made to a known disabled account which is never legitimate and indicates a malicious intent.
- 2) **Requires deeper investigation:** This attempt will be escalated to Tier2/3 Analyst to investigate further (check source IP, Investigate if user “Anni” has been targeted from other machines etc.

The screenshot shows a table of failed logon attempts for disabled users. The table has three columns: Username, Event logged by, and # of logins. The data is as follows:

Username	Event logged by	# of logins
anni	WS001	1

3. Failed Logon Attempts [Admin user only]

Failed logon attempts (Admin users only)			
Username	Event logged by	Logon type	# of logins
Administrator	DC1	Interactive	3
administrator	PAW	Interactive	2
Administrator	DC1	Unlock	1
administrator	PAW	Unlock	1
administrator	DC2	Interactive	1

There is no suspicious activity because all failed admin logon attempts occurred either on a PAW or a Domain Controller, which aligns with company's policy that admin should only be using those specific, secure systems for administrative work. No attempts originated from unauthorized systems. No escalation is required.

4. RDP Logon for Service Account

RDP logon for service account			
Username	Connect to	Connect from	# of logins
svc-sql1	PKI	192.168.28.130	2

Immediate escalation to Tier 2/3 Analyst is required. Service account **svc-sql1** successfully established 2 RDP sessions from IP **192.168.28.130**.

- **Service accounts should never be used for interactive RDP logins.**
- **Successful logon means credentials are compromised or being misused**
- **Violates multiples security policies and possible compromise of privileged escalation.**

5. User added or removed from a local group

User added or removed from a local group					
Mar 5, 2023 @ 17:00:00.000 to now					
User performing the action	User added	Group modified	Action permed	Action performed on	Count of records
Administrator	S-1-5-21-1518138621-4282902...	Administrators	added-member-to-group	PKI.eagle.local	1

Admin account added a user to local Administrator group on the PKI server.

It is better to consult with IT operations to verify it this was a:

- Legitimate administrative task
- Know issue with user account resolution

- Authorized change during maintenance

Always consult with the system owners before escalating potential policy violations, preventing unnecessary incident tickets for legitimate administrative security.

6. Admin logon not from PAW

Admin logon not from PAW Feb 28, 2023 @ 17:00:00.000 to now		
User	Connect from	Count of records
Administrator	192.168.28.132	51
Administrator	192.168.28.200	8
Administrator	fe80::da26:ad7f:80ca:8a7b	1

Administrator account shows high volume of logon (51 and 8) from two non-PAW IP addresses.

- Stated by senior analyst IT team often uses default administrator account against policy so that could be the reason.
- This could easily be **False Positive** (could be specific IT admin who consistently uses their regular desktop for admin work)
- Confirm with IT operations whether it is non-compliant behavior or not before escalation.

7. SSH Logins

elastic Search Elastic						
Dashboard	SOC-Alerts	Full screen	Share	Clone	Edit	
SSH Logins						
Action	User	Outcome	Authentication	From	Count of records	
ssh_login	root	Failed	password	192.168.28.150	6	

6 failed SSH Login attempts were observed from **root** user from IP **192.168.28.150**

- Senior Analyst stated root user account is not used, any remote login from root is direct violation of security control.
- Repeated failed password-based logins for most privileged account is a sign of a brute-force attack.

